

DOCUMENTO DE ARQUITECTURA

BANCA POR

INTERNET

Juan Fernando Loachamín

Arquitecto

Juan.loachamin@gmail.com

BANCA

Fecha: 30/10/2025

TABLA DE CONTENIDO

REVISIÓN Y APROBACIÓN DEL DOCUMENTO.....	5
DEFINICIONES, ACRÓNIMOS Y ABREVIATURAS.....	6
INTRODUCCIÓN	8
Descripción General de la aplicación.....	8
Restricciones de la solución.....	9
Requerimientos no funcionales (RNF).....	10
DECISIONES ARQUITÉCTONICAS JUSTIFICADAS	12
DA-01 — Framework Frontend Web: React (SPA)	12
DA-02 — Framework Móvil Multiplataforma	12
DA-03 — API Gateway: Azure API Management (APIM).....	13
DA-04 — Auditoría: Patrón CQRS + Event Sourcing	13
DA-05 — Persistencia para Clientes Frecuentes: Redis con Patrón Cache-Aside	13
DA-06 — Notificaciones: Azure Communication Services + Firebase FCM.....	14
DA-07 — Autenticación: Microsoft Entra External ID con OAuth 2.0	14
Consideraciones regulatorias y de seguridad.....	16
Context Diagram C4 Nivel 1	17
Container Diagram C4 Nivel 2	18
Inventario de contenedores	18
Component Diagram C4 Nivel 3: Azure Api Management	20

Component Diagram C4 Nivel 3: Tranfer Service	21
Autenticación y Autorización – Oauth 2.0 con PKCE	22
Onboarding con Reconocimiento Facial.....	22
Herramientas de biometría evaluadas	23
Auditoria Patrón CQRS + Event Sourcing.....	24
Persistencia para clientes frecuentes: Patrón Cache-Aside	26
ALTA DISPONIBILIDAD	27
RECUPERACIÓN ANTE DESASTRES(DR).....	28
MONITOREO EXCELENCIA OPERATIVA Y AUTO-HEALING	29
Stack de Observabilidad — Tres Pilares	29
Auto-healing	29
Alertas y Escalación	29
ARQUITECTURA DE AMBIENTES, REDES Y SEGURIDAD.....	31
Modelo Landing Zone	31
Topología	32
Principios de Diseño y Estándares de Gobernanza	32
Modelo de Segregación por Ambientes (DEV/QA/PROD).....	32
Principios de Conectividad	33
Conectividad Interna (Private Endpoints y DNS).....	33
Controles de Seguridad de Red	33

ARQUITECTURA TECNOLÓGICA Y DE DESPLIEGUE	34
Servicios Azure.....	34
COSTOS AZURE	38
Costos ambiente desarrollo.....	38
Costos ambientes QA	39
Costos ambientes PRD.....	39
Costos Servicios transversales.....	40

REVISIÓN Y APROBACIÓN DEL DOCUMENTO

Historial de cambios:

Versión	Autor	Fecha	Descripción
1.0	Juan Fernando Loachamin	2026-04-25	Generación del documento

Aprobado por:

Nombre	Cargo	Fecha

DEFINICIONES, ACRÓNIMOS Y ABREVIATURAS

Glosario de términos técnicos, acrónimos y abreviaturas utilizados en este documento de arquitectura. Facilita la comprensión y unifica definiciones entre stakeholders técnicos y de negocio.

Acrónimo / Abreviatura	Significado
ACH	Automated Clearing House — red de compensación electrónica interbancaria
API	Application Programming Interface
AKS	Azure Kubernetes Service
APIM	Azure API Management
BFF	Backend For Frontend — patrón de API especializado por canal
CDN	Content Delivery Network
CI/CD	Continuous Integration / Continuous Deployment
CQRS	Command Query Responsibility Segregation
DR	Disaster Recovery — recuperación ante desastres
FCM	Firebase Cloud Messaging — servicio de notificaciones push de Google
HA	High Availability — alta disponibilidad
IdP	Identity Provider — proveedor de identidad
JWT	JSON Web Token
KYC	Know Your Customer — verificación de identidad del cliente
MFA	Multi-Factor Authentication — autenticación multifactor
OIDC	OpenID Connect
OWASP	Open Web Application Security Project
PCI-DSS	Payment Card Industry Data Security Standard
PKCE	Proof Key for Code Exchange
RBAC	Role-Based Access Control — control de acceso basado en roles

Acrónimo / Abreviatura	Significado
RPO	Recovery Point Objective — objetivo de punto de recuperación
RTO	Recovery Time Objective — objetivo de tiempo de recuperación
SPA	Single Page Application
SWIFT	Society for Worldwide Interbank Financial Telecommunication
TLS	Transport Layer Security
TTL	Time to Live
VNet	Virtual Network — red virtual en Azure
WAF	Web Application Firewall

INTRODUCCIÓN

El presente documento describe el diseño de arquitectura de soluciones para el sistema de Banca por Internet de BP. El objetivo es definir una arquitectura robusta, segura, escalable y alineada con las regulaciones del sector financiero, que permita a los clientes de BP acceder a sus productos bancarios de forma digital, ágil y confiable.

El diseño sigue el modelo C4 (Context, Containers, Components, Code), descomponiendo el sistema en tres niveles de abstracción para audiencias técnicas y no técnicas.

La arquitectura está orientada a soportar dos canales digitales principales: una aplicación web SPA y una aplicación móvil multiplataforma con capacidades de consulta de movimientos, transferencias, pagos, onboarding biométrico, notificaciones normativas y auditoría completa de acciones del cliente.

Descripción General de la aplicación

El sistema de banca por internet permitirá a los usuarios acceder al histórico de sus movimientos, realizar transferencias y pagos entre cuentas propias e interbancarias.

El sistema cuenta con dos aplicaciones frontend: una SPA web y una aplicación móvil desarrollada en un framework multiplataforma. Ambas autentican a los usuarios mediante un servicio OAuth 2.0 configurado sobre un producto existente de BP.

La información del cliente proviene de dos fuentes: el Core Banking Platform, que contiene datos básicos del cliente, movimientos y productos, y un sistema independiente que complementa esa información cuando se requiere mayor detalle.

Para la obtención de datos, el sistema pasa por una capa de integración compuesta por un API Gateway que enruta las solicitudes a tres servicios principales: consulta de datos básicos, consulta de movimientos y transferencias. Estos servicios realizan llamados a sistemas externos según el tipo de transacción.

Los nuevos clientes se incorporan a través de un flujo de onboarding en la aplicación móvil que incluye reconocimiento facial. Una vez registrados, pueden autenticarse mediante usuario y clave, huella u otro método biométrico.

Toda acción del cliente queda registrada en una base de datos de auditoría con mecanismo de persistencia optimizado para clientes frecuentes. Adicionalmente, la normativa exige que los usuarios sean notificados sobre cada movimiento realizado, para lo cual el sistema utiliza mínimo dos servicios de envío de notificaciones.

Restricciones de la solución

Las siguientes restricciones delimitan el espacio de decisiones arquitectónicas.

#	Restricción
R01	La autenticación debe implementarse sobre el estándar OAuth 2.0, utilizando un producto existente configurable para este fin. No se permite implementar la lógica de autenticación desde cero.
R02	La información del cliente debe obtenerse exclusivamente desde dos sistemas: el Core Banking Platform y el Sistema Independiente de Detalle del Cliente.
R03	El sistema debe contar con mínimo dos servicios de notificación para informar al usuario sobre sus movimientos
R04	El frontend debe incluir obligatoriamente dos aplicaciones: una SPA web y una aplicación móvil desarrollada en un framework multiplataforma
R05	El onboarding de nuevos clientes en la aplicación móvil debe incluir reconocimiento facial como parte del flujo de autenticación y autorización.
R06	La capa de integración debe estar compuesta por un API Gateway que exponga mínimo tres servicios: consulta de datos básicos, consulta de movimientos y transferencias

R07	La arquitectura debe modelarse bajo el estándar C4, hasta el nivel de componentes
R08	Toda acción del cliente debe quedar registrada en una base de datos de auditoría con un mecanismo de persistencia para clientes frecuentes.
R09	La arquitectura debe garantizar alta disponibilidad, tolerancia a fallos, recuperación ante desastres, seguridad y monitoreo.

Requerimientos no funcionales (RNF)

Los siguientes atributos de calidad guían todas las decisiones de diseño de la arquitectura.

#	Atributo	Descripción
RNF01	Disponibilidad	El sistema debe operar de forma continua sin interrupciones perceptibles para el usuario.
RNF02	Tolerancia a Fallos	El sistema debe continuar operando ante la falla de uno o más componentes internos, sin afectar la experiencia del usuario.
RNF03	Recuperación ante Desastres	El sistema debe poder restaurarse ante un fallo catastrófico de infraestructura con el menor impacto posible.
RNF04	Seguridad	El sistema debe proteger los datos del cliente, garantizar accesos autorizados y resistir amenazas comunes en canales digitales
RNF05	Monitoreo	El sistema debe permitir detectar, diagnosticar y resolver incidentes operativos en tiempo real.
RNF06	Excelencia Operativa y Auto-healing	El sistema debe ser capaz de detectar y recuperarse automáticamente de fallos sin intervención manual.

RNF07	Escalabilidad	El sistema debe adaptarse al crecimiento de usuarios y volumen de transacciones sin degradación del servicio.
RNF08	Baja Latencia	El sistema debe minimizar los tiempos de respuesta, especialmente para usuarios frecuentes mediante mecanismos de caché.
RNF09	Desacoplamiento	La arquitectura debe estar compuesta por elementos independientes, cohesivos y reutilizables que soporten la adición de nuevos componentes en el futuro.
RNF10	Cumplimiento Normativo	El sistema debe cumplir con la regulación aplicable a entidades financieras en materia de datos personales y seguridad.

DECISIONES ARQUITÉCTONICAS JUSTIFICADAS

DA-01 — Framework Frontend Web: React (SPA)

Framework	Ventajas	Desventajas
React	Mayor adopción, ecosistema amplio, Virtual DOM, flexibilidad arquitectónica, gran disponibilidad de talento.	No es un framework completo (requiere librerías adicionales para routing, estado). Curva inicial por decisiones de arquitectura.
*Angular	Framework completo. TypeScript obligatorio. Inyección de dependencias, routing, formularios y HTTP client integrados. Soporte LTS garantizado. Preferido por industrias reguladas: finanzas, salud, gobierno.	Mayor curva de aprendizaje, bundle base más grande, menor flexibilidad para proyectos con arquitectura propia.

DA-02 — Framework Móvil Multiplataforma

Framework	Ventajas	Desventajas
Flutter	Compila a código nativo ARM (sin puente JS), rendimiento superior para animaciones y biometría, un codebase para iOS y Android, motor gráfico Skia/Impeller garantiza consistencia visual.	Lenguaje Dart menos conocido que JS/TS, comunidad más pequeña que React Native, tamaño de app mayor por incluir el motor gráfico.
React Native	Reutilización de conocimiento JavaScript/React del equipo web, comunidad grande, ecosistema maduro.	Puente JavaScript introduce latencia en operaciones intensivas (biometría, reconocimiento facial).
.NET MAUI	Integración nativa con Azure y Active Directory, C# compartido con backend .NET, ideal en ecosistemas Microsoft.	Comunidad móvil más pequeña, menor madurez en funcionalidades biométricas avanzadas, rendimiento

Framework	Ventajas	Desventajas
		inferior en animaciones complejas.

DA-03 — API Gateway: Azure API Management (APIM)

- Justificación 1 — Patrón Facade / BFF: el API Gateway implementa el patrón Facade, exponiendo una interfaz unificada que oculta la complejidad de los microservicios internos. Reduce el acoplamiento entre los clientes (SPA, app móvil) y los servicios de backend.
- Justificación 2 — Centralización de políticas de seguridad: rate limiting, validación de JWT, y transformación de requests se gestionan en un único punto, evitando duplicar lógica de seguridad en cada microservicio y reduciendo la superficie de ataque.

DA-04 — Auditoría: Patrón CQRS + Event Sourcing

- Justificación 1 — Inmutabilidad requerida por regulación bancaria: los registros de auditoría en entidades financieras no pueden modificarse ni eliminarse. Event Sourcing almacena el estado como secuencia de eventos inmutables (append-only log), haciendo detectable cualquier intento de alteración.
- Justificación 2 — CQRS para escalabilidad independiente: separar el modelo de escritura (registro de eventos) del modelo de lectura (consultas de compliance y reportes) permite escalar ambas dimensiones de forma independiente. Los picos de escritura no afectan las consultas de auditoría.

DA-05 — Persistencia para Clientes Frecuentes: Redis con Patrón Cache-Aside

- Justificación 1: Patrón Cache-Aside (Lazy Loading): la aplicación primero consulta Redis, obtiene el dato del origen y lo almacena. Evita cargar en caché datos que no se demandan frecuentemente, optimizando el uso de memoria.
- Justificación 2: Reducción de carga sobre el Core Banking Platform: las consultas al Core Banking tienen latencia de red por ser un sistema externo. Redis en memoria entrega respuestas sub-milisegundo para saldos y movimientos

frecuentes, reduciendo significativamente la carga sobre el sistema de origen (no debe ser usado para datos cuando los datos son confidenciales o relacionados con la seguridad).

- Invalidación: las entradas de caché se invalidan mediante un evento publicado en el bus de mensajería cuando ocurre una nueva transacción, garantizando consistencia eventual sin consultas innecesarias al origen.
- Referencia: <https://learn.microsoft.com/es-es/azure/architecture/patterns/cache-aside>

DA-06 — Notificaciones: Azure Communication Services + Firebase FCM

Se adoptan dos canales: Email/SMS mediante Azure Communication Services (servicio administrado de Azure) y notificaciones push mediante Firebase Cloud Messaging (FCM).

- Justificación 1: Redundancia de canal, si un canal falla, el segundo garantiza la entrega de la notificación al usuario, cumpliendo el requisito normativo de informar sobre cada movimiento.
- Justificación 2: Desacoplamiento mediante bus de eventos: los servicios de notificación suscriben a eventos del bus (Azure Service Bus) en lugar de ser llamados directamente por los servicios de transacción. Esto desacopla el flujo transaccional del flujo de notificación, evitando que una falla en notificaciones bloquee una transferencia.

DA-07 — Autenticación: Microsoft Entra External ID con OAuth 2.0

Banco ya cuenta con un producto configurable para OAuth 2.0. Se propone Microsoft Entra External ID

- Justificación 1: Producto configurable, no implementación desde cero, Microsoft Entra External ID soporta múltiples proveedores de identidad, incluyendo cuentas de Microsoft Entra, Facebook, Google, Apple, federación con Microsoft Entra ID, OIDC personalizado y federación con proveedores

SAML/WS-Fed. Se puede configurar los flujos de usuario requeridos (sign-in, sign-up, MFA, biometría) sin escribir lógica de autenticación propia.

- **Justificación 2: Soporte completo de OAuth 2.0 / OIDC y PKCE:** Microsoft Entra External ID emite tokens estándar OIDC y OAuth 2.0 que se integran directamente con aplicaciones y APIs modernas. Para SPAs y aplicaciones móviles, que son clientes públicos que no pueden guardar un client_secret, se debe usar Authorization Code con PKCE. Esto se alinea directamente con el flujo recomendado para el SPA Angular o React y la app Flutter del proyecto.
- **Justificación 3: Integración nativa con Azure API Management:** Los tokens JWT emitidos por Microsoft Entra External ID pueden validarse en Azure API Management verificando la firma (JWKS), el issuer, el audience y los scopes/roles. Esto permite centralizar la validación de tokens en el API Gateway sin lógica adicional en cada microservicio.
-

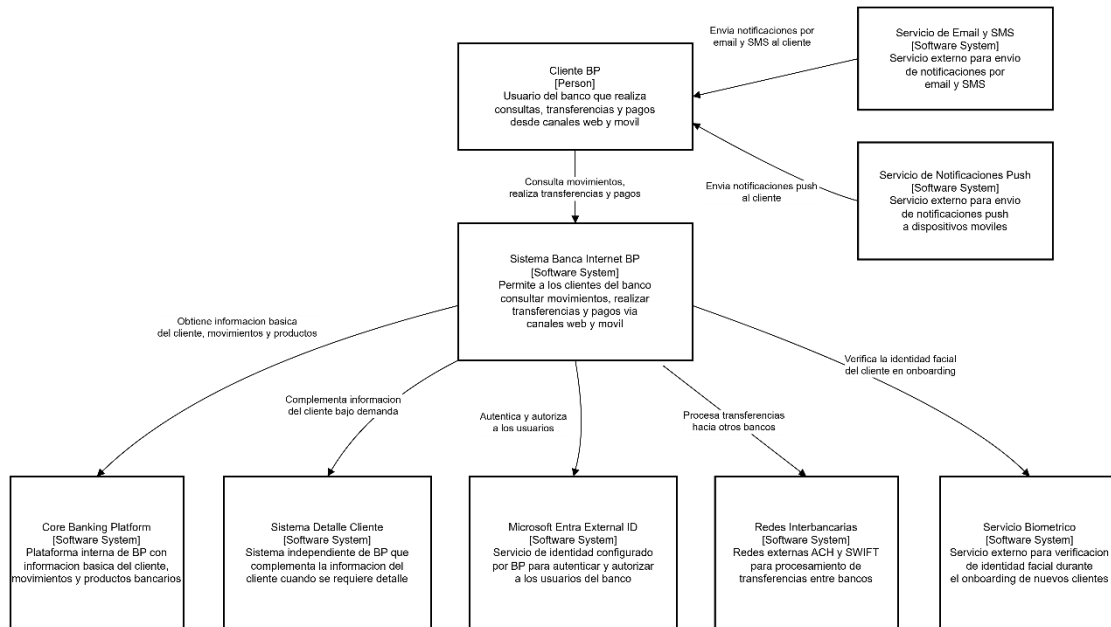
Consideraciones regulatorias y de seguridad

Los siguientes estándares internacionales son aplicables a cualquier banco, independientemente del país de operación:

Norma / Estándar	Impacto Arquitectónico
PCI-DSS	Estándar de seguridad para protección de datos de tarjetahabientes. Exige segmentación de red, cifrado de datos en tránsito y en reposo, gestión de accesos privilegiados y registro de actividad.
ISO/IEC 27001	Marco de gestión de seguridad de la información. Los controles de operaciones, comunicaciones y desarrollo seguros son directamente aplicables a la arquitectura.
SWIFT CSP	SWIFT Customer Security Programme. Aplica a sistemas que procesan transferencias interbancarias. Exige controles de acceso, monitoreo de actividad inusual y protección del entorno de mensajería.
OWASP Top 10	Referencia de vulnerabilidades críticas en aplicaciones web. La arquitectura mitiga: Broken Access Control (RBAC + OAuth 2.0), Cryptographic Failures (TLS 1.3 + cifrado en reposo), Injection (ORM + validación de entradas), Insecure Design (arquitectura de defensa en profundidad).
Regulación de Datos Personales	Cualquier banco debe cumplir con la legislación de protección de datos personales de su jurisdicción. La arquitectura garantiza cifrado de PII, control de acceso a datos sensibles y capacidad de eliminación/rectificación de datos bajo demanda.
Basilea III — Riesgo Operativo	Exige a los bancos gestionar el riesgo operativo, incluyendo fallas de sistemas tecnológicos. La arquitectura responde con HA, DR, Circuit Breakers y planes de continuidad.

Context Diagram C4 Nivel 1

El System Context muestra el sistema en el centro, rodeado únicamente de las personas y sistemas externos con los que interactúa directamente. Audiencia: técnica y no técnica.



Container Diagram C4 Nivel 2

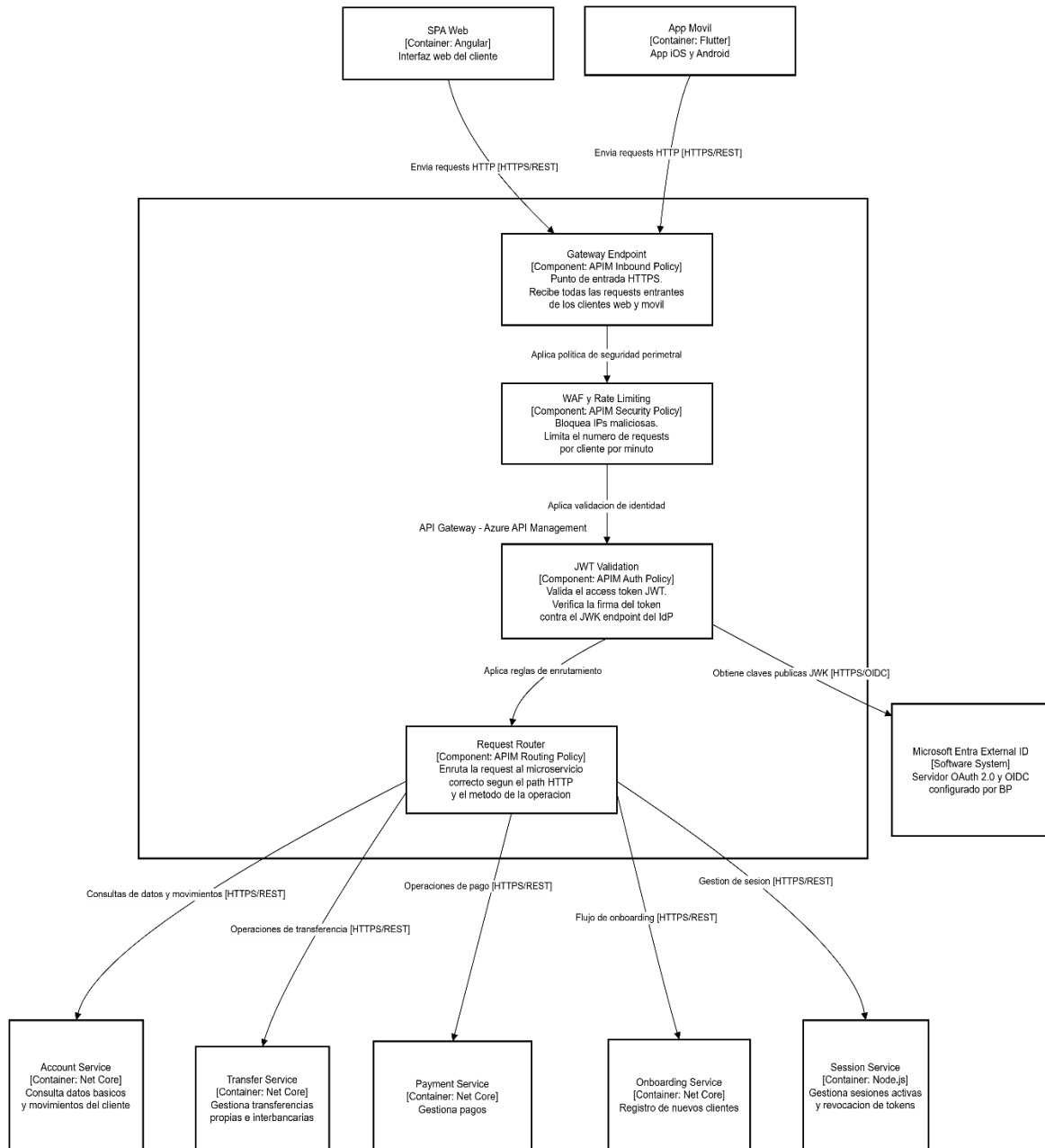
El Container Diagram muestra las aplicaciones, microservicios, bases de datos y colas que componen el sistema, con sus tecnologías y protocolos de comunicación. No incluye detalles de despliegue (clustering, load balancers). Audiencia: técnica.

Inventario de contenedores

Contenedor	Tecnología	Responsabilidad
SPA Web	Angular + TypeScript	Interfaz web del cliente. Single Page Application. Se comunica con APIM via HTTPS/REST.
App Móvil	Flutter	App iOS/Android. Incluye biometría en onboarding y autenticación. Consume APIM via HTTPS/REST.
Azure API Management	Azure APIM	Punto único de entrada. Rate limiting, validación JWT, routing a microservicios. HTTPS/REST.
Account Service	.NET 10 / ASP.NET Core	Consulta datos básicos del cliente y movimientos. Integra Core Banking Platform via HTTPS/REST.
Transfer Service	.NET 10 / ASP.NET Core	Gestiona transferencias propias e interbancarias. Publica eventos al Service Bus via AMQP.
Payment Service	.NET 10 / ASP.NET Core	Gestiona pagos. Integra redes interbancarias ACH/SWIFT via HTTPS/REST.
Onboarding Service	.NET 10 / ASP.NET Core	Gestiona el flujo de registro de nuevos clientes. Integra Azure Face API para reconocimiento facial via HTTPS/REST.
Notification Service	.NET 10 Azure Functions o Node.js	Suscribe a eventos del Service Bus (AMQP). Envía Push via FCM (HTTPS) y Email/SMS via Azure Communication Services (HTTPS).
Audit Service	.NET 10 / ASP.NET Core	Suscribe a todos los eventos del Service Bus. Registra acciones en la BD de Auditoría. Event Sourcing append-only.
Customer Detail Service	Node.js	Adapter hacia el Sistema Detalle Cliente externo. Consultado por Account Service via HTTPS/REST.
Session Service	Node.js	Gestiona sesiones activas, cierre por inactividad y revocación de tokens OAuth 2.0.
Azure Service Bus	Azure Service Bus	Bus de mensajería asíncrono. Desacopla Transfer/Payment/Onboarding de Notification y Audit. AMQP.

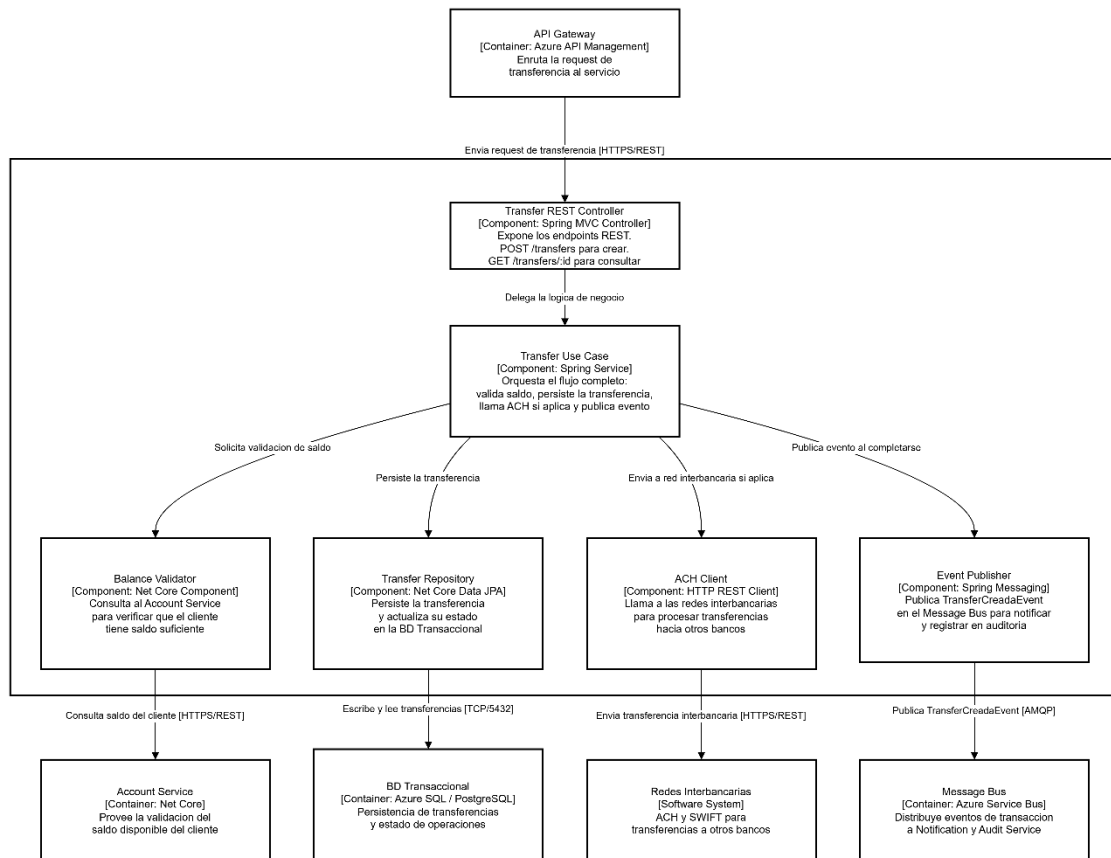
Component Diagram C4 Nivel 3: Azure Api Management

Este diagrama detalla el contenedor Azure Api Management, muestra los componentes internos que lo componen, sus responsabilidades y cómo se conectan con otros contenedores. Audiencia: arquitectos y desarrolladores.



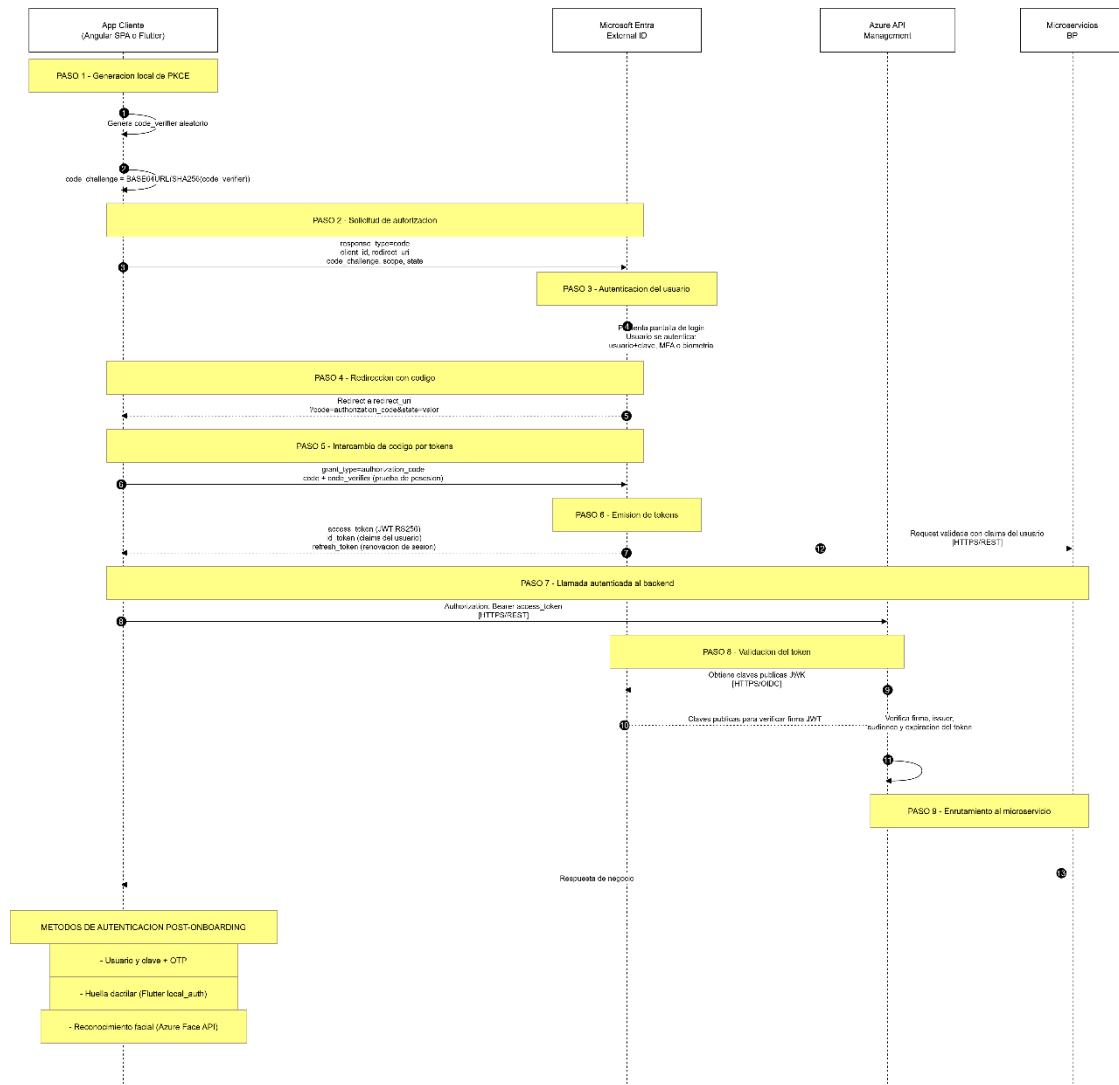
Component Diagram C4 Nivel 3: Tranfer Service

Este diagrama detalla el contenedor del microservicio de transferencias, es el más complejo del sistema ya que integra validación de saldo, persistencia, eventos asíncronos e integración con redes interbancarias por lo tanto deberá ser validado en una segunda revisión para cumplir los requerimientos del negocio.



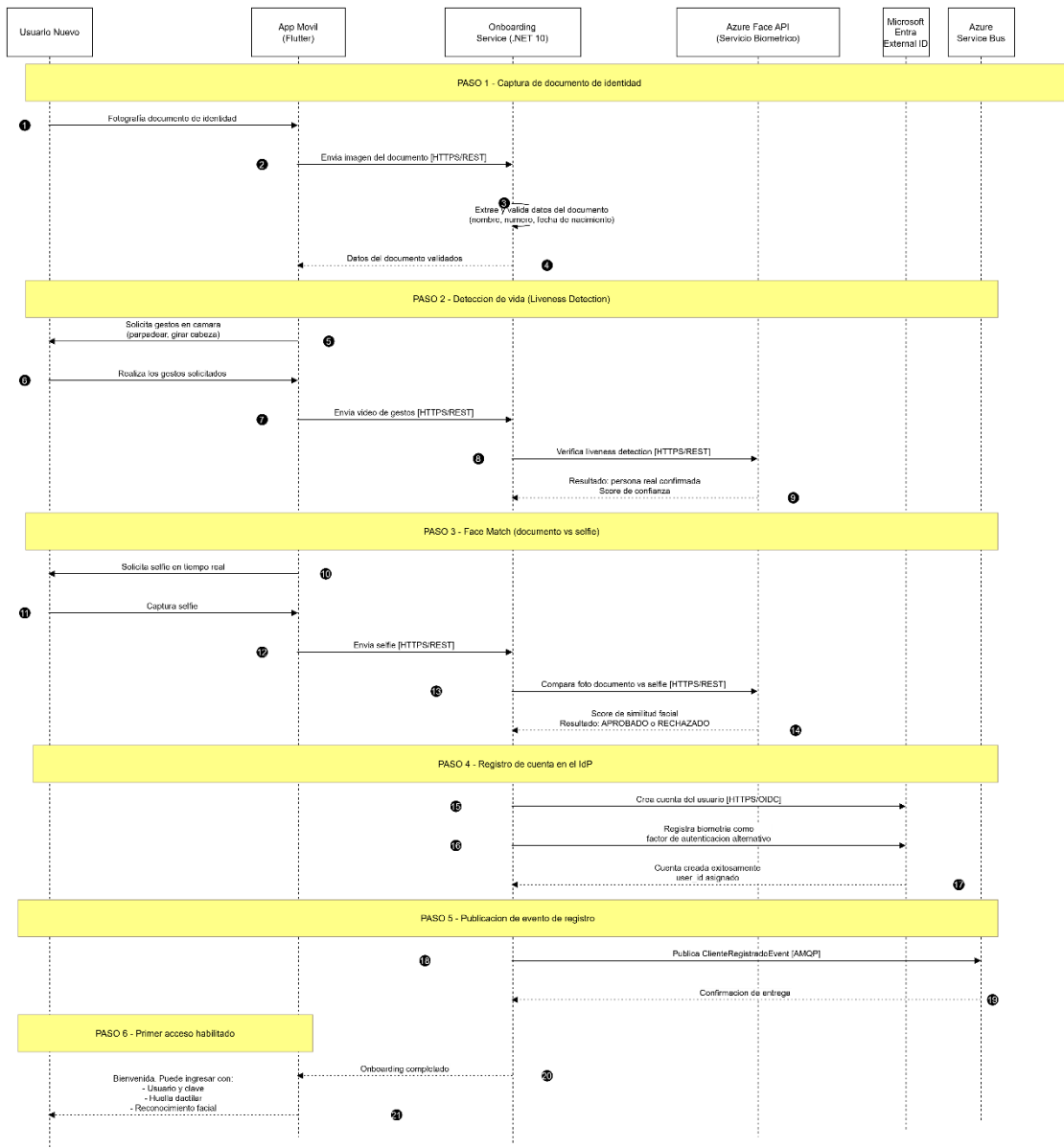
Autenticación y Autorización - OAuth 2.0 con PKCE

Ambas aplicaciones (SPA y app móvil) autentican a los usuarios mediante un servicio que usa el estándar OAuth 2.0. BP ya cuenta con un producto configurable para este fin: Microsoft Entra External ID.



Onboarding con Reconocimiento Facial

El sistema de onboarding para nuevos clientes en la aplicación móvil usa reconocimiento facial. Su arquitectura forma parte del flujo de autorización y autenticación. Desde el onboarding el nuevo usuario podrá ingresar al sistema mediante usuario y clave, huella u otro método biométrico.



Herramientas de biometría evaluadas

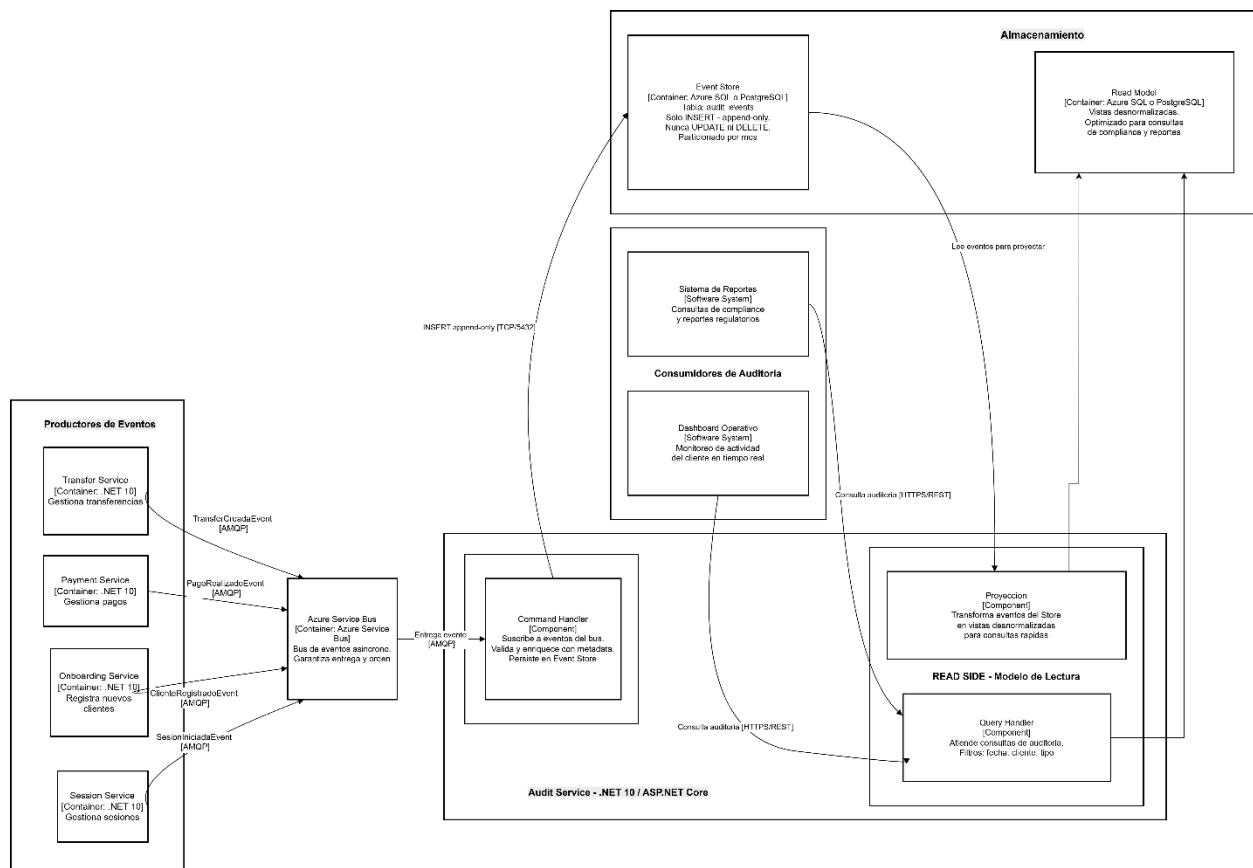
Herramienta	Tipo	Precio Referencial	Evaluación
Azure Face API	Face Match + Liveness	Desde USD \$1 por 1.000 transacciones. Sin licencia fija.	Integración nativa con Microsoft Entra External ID y Azure APIM. Servicio administrado sin infraestructura propia. Servicio administrado sin infraestructura propia. Elección principal por ecosistema Azure.
Onfido	KYC completo + Biometría	Desde USD \$1.50 por verificación de identidad completa.	Plataforma especializada en KYC bancario: verificación de documento + biometría +

Herramienta	Tipo	Precio Referencial	Evaluación
			liveness. Opción complementaria si se requiere KYC regulatorio completo.
iProov	Liveness Detection especializado	Licenciamiento enterprise. Precio por volumen acordado contractualmente.	Especialista en detección de ataques de presentación (fotos, videos, máscaras 3D). Referente de la industria en bancos de alta seguridad.
AWS Rekognition	Face Match + Liveness	Desde USD \$1 por 1.000 imágenes.	Descartado. La nube seleccionada es Azure. Usar AWS Rekognition implicaría dependencia cruzada de nube sin beneficio justificado.

Auditoria Patrón CQRS + Event Sourcing

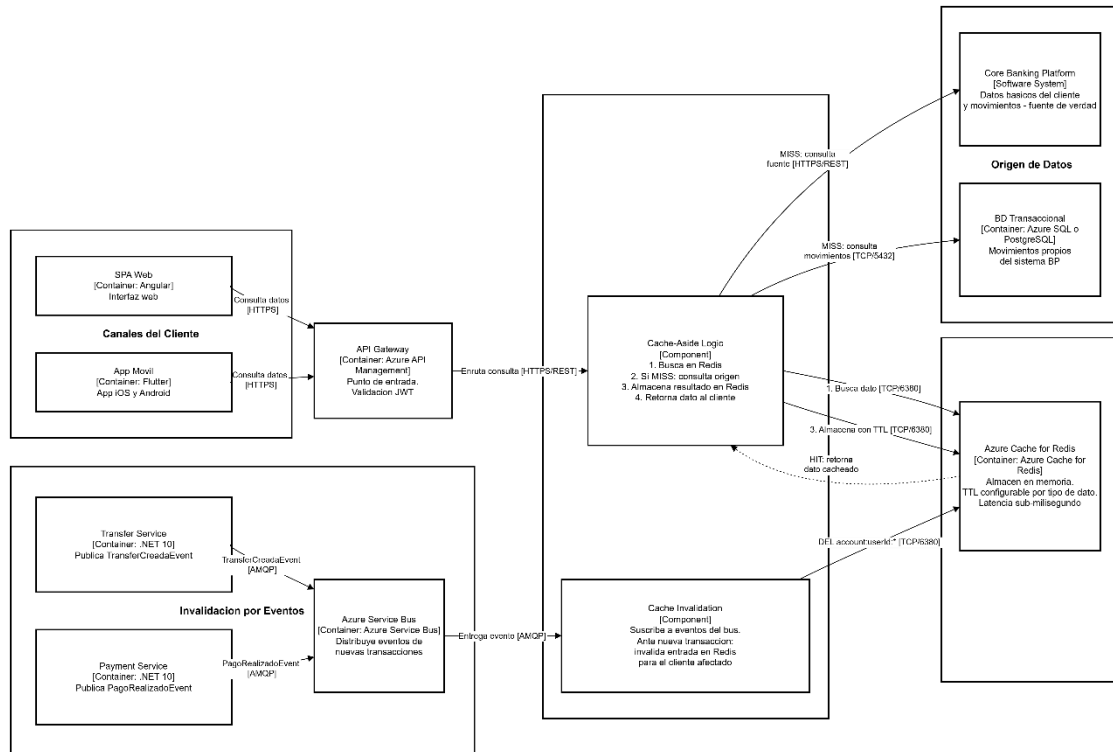
El sistema de utiliza una base de datos de auditoría que registra todas las acciones del cliente:

- CQRS (Command Query Responsibility Segregation) separa el modelo de escritura (registro de eventos) del modelo de lectura (consultas de auditoría), permitiendo escalar ambas dimensiones de forma independiente.
- Event Sourcing almacena el estado del sistema como una secuencia de eventos inmutables (append-only). Nunca se modifican ni eliminan registros pasados, garantizando la integridad del historial de auditoría.



Persistencia para clientes frecuentes: Patrón Cache-Aside

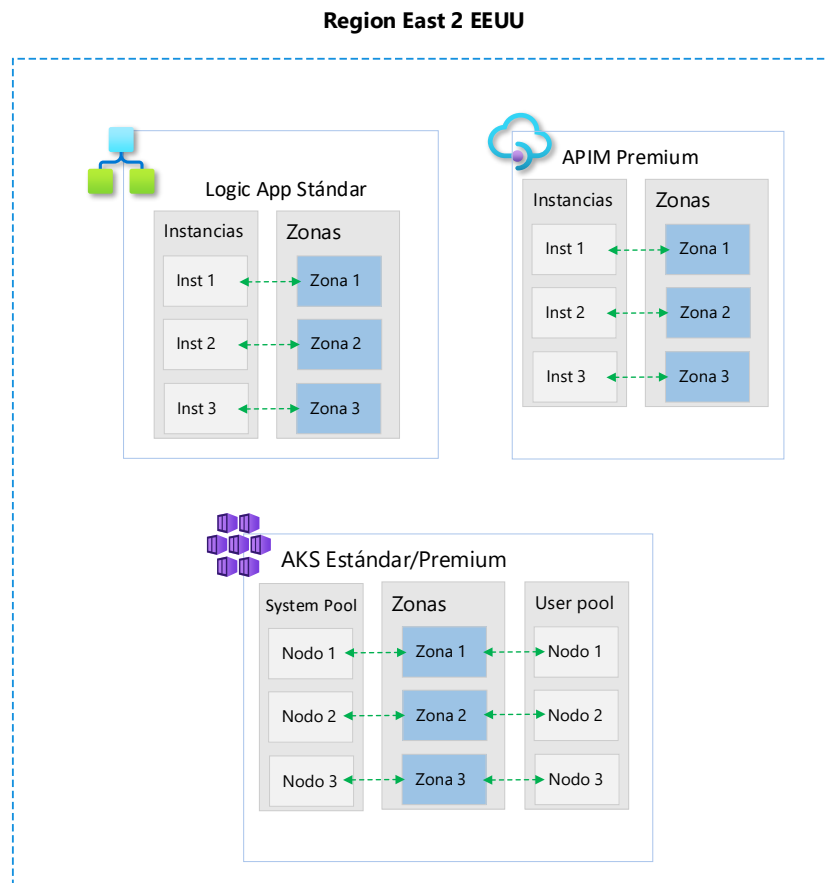
El sistema cuenta con un mecanismo de persistencia de información para clientes frecuentes. Se propone el patrón Cache-Aside sobre Azure Cache for Redis



ALTA DISPONIBILIDAD

Patrón / Componente	Implementación en Azure
Multi-zona (Availability Zones)	Todos los servicios críticos desplegados en mínimo 2 zonas de disponibilidad dentro de la misma región Azure.
Auto Scaling	Azure Kubernetes Service (AKS) con Horizontal Pod Autoscaler. Escala microservicios según carga.
Load Balancer	Azure Load Balancer + Azure Front Door para distribución de tráfico y health checks automáticos.
Circuit Breaker	Resilience en microservicios. Si Core Banking Platform o sistemas externos fallan repetidamente, el circuito se abre y se sirve desde caché o se retorna error controlado.

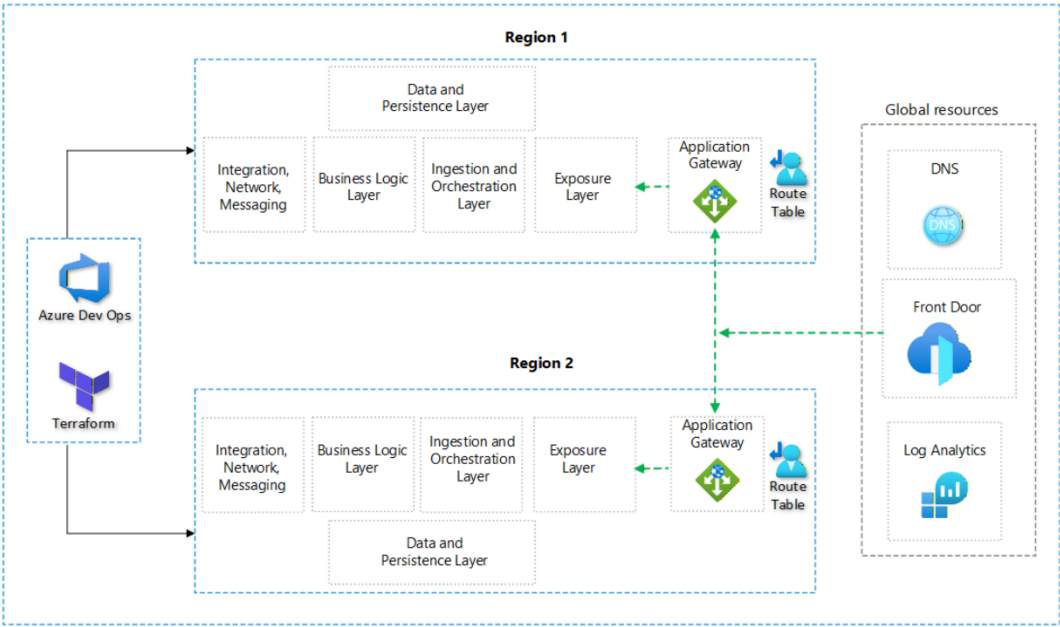
A continuación, se tiene un diagrama referencial de una arquitectura con 3 servicios configurado en 3 zonas de disponibilidad en una misma región.



RECUPERACIÓN ANTE DESASTRES(DR)

Aspecto		Implementación
Estrategia		Warm Standby en región secundaria Azure. Capacidad reducida en standby, escala automáticamente ante activación de DR.
Datos		Azure SQL Database o Azure PostgreSQL con réplicas de lectura en región secundaria y backups automáticos.
Infraestructura como Código		Terraform o Azure Bicep para despliegue reproducible. Ante un DR, la infraestructura se recrea automáticamente.
Simulacros		Pruebas periódicas de failover recomendadas para validar que los procedimientos de DR funcionan como se espera.

A continuación, se tiene un diagrama referencial de una arquitectura con una región secundaria.



MONITOREO EXCELENCIA OPERATIVA Y AUTO-HEALING

Stack de Observabilidad — Tres Pilares

Pilar	Herramienta Azure	Qué cubre
Logs	Azure Monitor Logs + Log Analytics Workspace	Logs estructurados (JSON) de todos los contenedores. Retención configurable. Búsqueda y alertas sobre logs.
Métricas	Azure Monitor Metrics + Application Insights	CPU, memoria, latencia, tasa de errores por servicio. Dashboards en tiempo real. Alertas automáticas.
Trazas	Application Insights + OpenTelemetry	Trazas distribuidas end-to-end entre microservicios. Identificación de bottlenecks y dependencias.

Auto-healing

- Azure Kubernetes Service (AKS) reinicia automáticamente contenedores que fallan los health checks (liveness probe) y los reemplaza si no responden (readiness probe).
- Azure Service Bus con Dead Letter Queue (DLQ): mensajes que fallan repetidamente son movidos a la DLQ para análisis sin perder el evento original.
- Circuit Breaker (Resilience4j): ante fallos repetidos de un servicio externo, el circuito se abre y se retorna una respuesta de fallback, evitando cascada de fallos.
- Azure Front Door con health probes: detecta backends no saludables y redirige tráfico a instancias sanas de forma automática.

Alertas y Escalación

- Azure Monitor Alerts: alertas automáticas ante errores HTTP 5xx, latencia elevada o uso de recursos por encima de umbral.

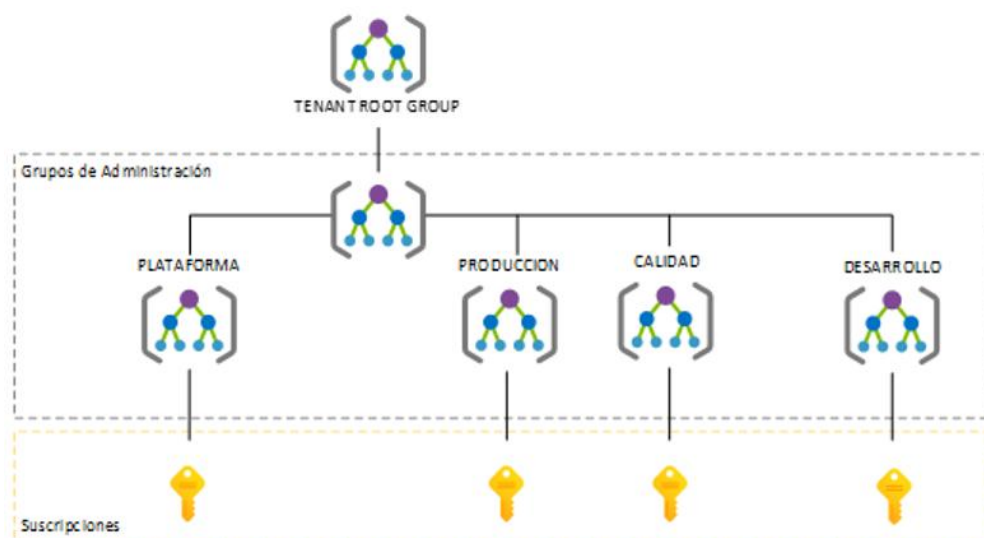
- Integración con Azure Logic Apps o webhooks para notificación al equipo de operaciones vía email, Teams o PagerDuty.

ARQUITECTURA DE AMBIENTES, REDES Y SEGURIDAD

Modelo Landing Zone

Se presenta una estrategia general de Landing Zone pero que deberá ser ajustada a la realidad del Banco que ofrece las siguientes ventajas:

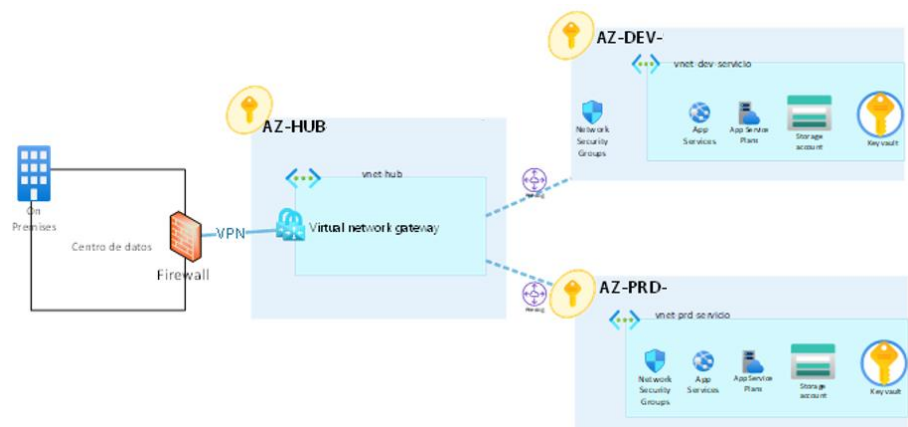
- Estructura jerárquica clara
 - Usa grupos de administración, suscripciones y grupos de recursos para separar entornos (dev, test, prod), unidades de negocio o proyectos.
 - Esto facilita la administración, el control de acceso y la facturación.
- Etiquetado estandarizado (tags)
 - Aplica etiquetas como owner, environment, costCenter, project, lo que permite clasificar y buscar recursos fácilmente.
- Políticas y convenciones de nombres
 - Define reglas para nombrar recursos de forma consistente, lo que mejora la visibilidad y evita confusiones.
- Control de acceso basado en roles (RBAC)
 - Asigna permisos específicos por grupo de recursos o suscripción, evitando accesos innecesarios o peligrosos.
- Visibilidad y monitoreo centralizado
 - Consolida logs, métricas y alertas en un solo lugar, facilitando la supervisión de todos los recursos.



Topología

El objetivo del diseño de red es alinear el diseño de red en la nube con los planes generales de adopción de la nube. Si los planes de adopción de la nube incluyen dependencias híbridas o multinube, o si se necesita conectividad por otros motivos, el diseño de red también debe incorporar esas opciones de conectividad y los patrones de tráfico esperados.

Se recomienda manejar una arquitectura hub-and-spoke a nivel de suscripciones como se muestra en el siguiente diagrama referencial



Principios de Diseño y Estándares de Gobernanza

Principios de diseño y estándares de gobernanza de red, seguridad y operaciones tienen los siguientes elementos:

Modelo de Segregación por Ambientes (DEV/QA/PROD)

Modelo de segregación mínimo por ambientes (DEV/QA/PROD) usando suscripciones o VNet Peering. Estándares de nomenclatura y separación de recursos para cumplimiento y control de cambios.

Development (DEV)	Desarrollo y pruebas unitarias. Restricciones de costos y acceso limitado.
Quality Assurance (QA)	Pruebas de integración, rendimiento y seguridad.

Production (PROD)	Operación en vivo del sistema con todas las seguridades y monitoreo.
--------------------------	--

Principios de Conectividad

Patrón Hub-Spoke como estándar. Política de Cero Exposición Pública para todos los servicios PaaS (Private Endpoints obligatorios).

Conectividad Interna (Private Endpoints y DNS)

Flujo: Cómputo (Functions/Logic, AKS) → VNet Integration → Private Endpoint → Servicio PaaS. No se permite acceso público directo.

Controles de Seguridad de Red

Grupos de Seguridad de Red (NSG)	NSG por subred y NSG a nivel de NIC para microsegmentación. Reglas por defecto deny all inbound, allow necessary outbound.
Deshabilitación Pública	Todos los PaaS con acceso público deshabilitado y accesibles solo por Private Endpoint. Storage, OpenAI, Search: solo PEs.
Azure Firewall (Hub)	Egress control / FQDN filtering / TLS inspection opcional. Registros de flujo enviados a Log Analytics. Forzar UDRs en spokes para pasar por Firewall.
Registro y Retención	Flujos NSG/Firewall, Azure Activity Logs, Diagnostic Settings y Audit Logs hacia Log Analytics/Storage con retención definida por políticas.

ARQUITECTURA TECNOLÓGICA Y DE DESPLIEGUE

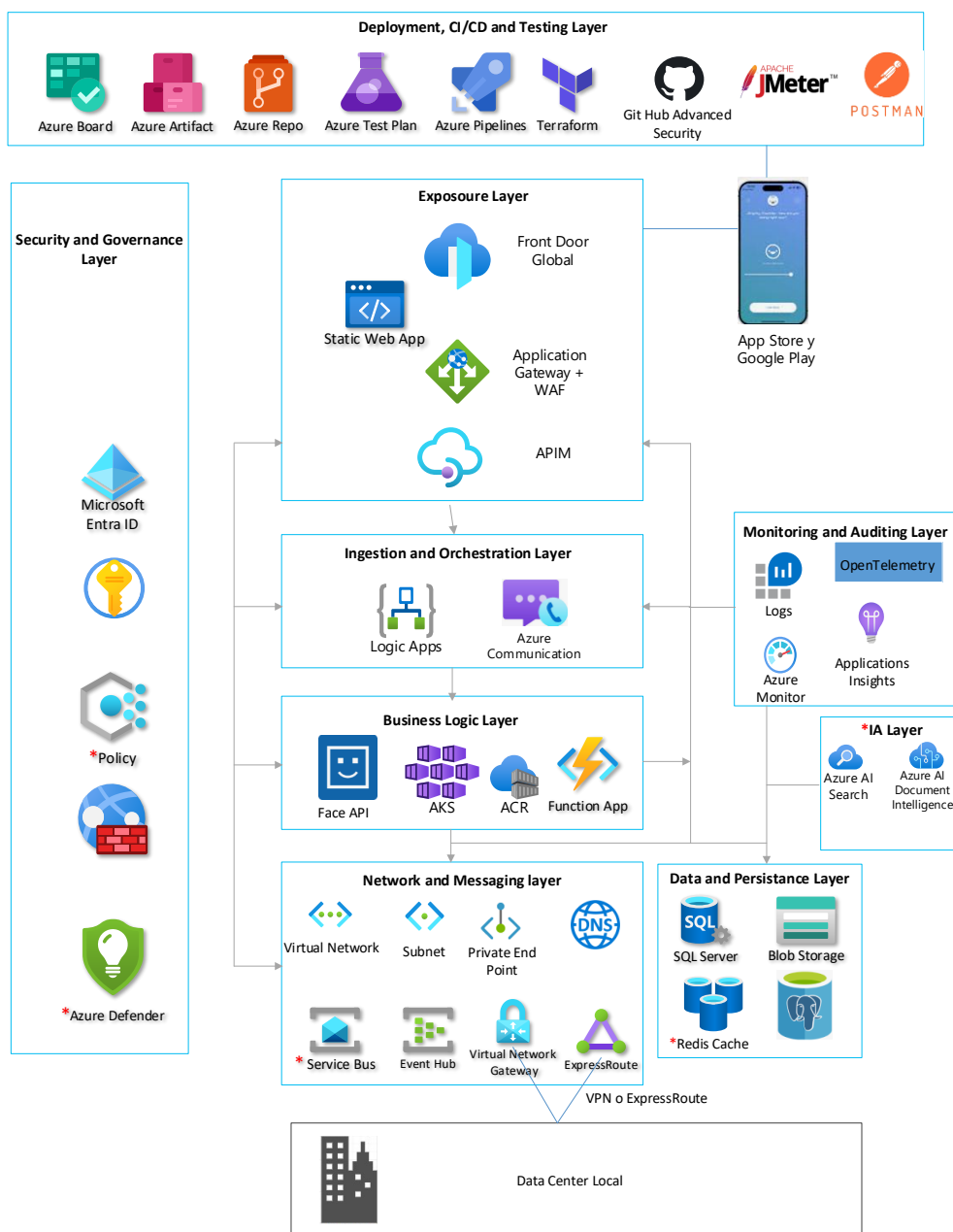
Servicios Azure

Capa	Servicio / Tecnología	Justificación
Exposure Layer	Azure Front Door (incluye CDN + WAF global)	Punto de entrada global. Azure Front Door es el frontend y punto único de ingreso a la aplicación, con WAF integrado que protege contra exploits.
	Azure Application Gateway (con WAF v2 habilitado)	Balanceador de carga L7 regional. Application Gateway enruta el tráfico hacia API Management. WAF no es un servicio independiente — es una capacidad habilitada dentro de Application Gateway.
	Azure API Management (APIM)	Gateway de APIs. API Management es una plataforma de gestión y gateway para APIs en todos los entornos, con rate limiting, autenticación y caching.
	SPA Web (Angular + TypeScript)	Interfaz web del cliente. Canal de acceso, no un servicio Azure. Consume APIM via HTTPS/REST
	App Móvil (Flutter)	Interfaz móvil iOS/Android. Canal de acceso, no un servicio Azure. Consume APIM via HTTPS/REST
Security and Governance Layer	Microsoft Entra ID / Microsoft Entra External ID	Identidad, autenticación y autorización. OAuth 2.0 / OIDC. Capa transversal que protege todos los accesos
	Azure Key Vault	Gestión centralizada de secretos, certificados y claves de cifrado. Consumido por todos los servicios que necesitan credenciales
	Azure Policy	Governance y cumplimiento normativo automatizado sobre todos los recursos Azure
	Microsoft Defender for Cloud	Protección de workloads y detección de amenazas. Antes llamado Azure Defender. Capa transversal de seguridad
Integration and	Azure Logic Apps	Logic Apps encaja como capa de orquestación en Azure Integration: workflows enterprise, conectores e integración entre sistemas.

Capa	Servicio / Tecnología	Justificación
Orchestration Layer	Firebase FCM (v1)	FCM es el servicio de transporte externo de Google para notificaciones push. Azure no habla directamente a dispositivos Android — envía mensajes a través del servicio FCM de Google.
	Azure Communication Services	Servicio administrado de Azure para envío de email y SMS. Canal de salida externo al sistema, paralelo a FCM. Consumido por Notification Service
Business Logic Layer	Azure Kubernetes Service — AKS	Plataforma de orquestación de contenedores donde corren los microservicios.
	Kubernetes Pods	Microservicios de negocio contenedorizados corriendo dentro del clúster AKS
	Azure Container Registry (ACR)	Registro de imágenes de contenedores. Soporte directo del entorno AKS.
	Azure Function App	Cómputo serverless event-driven para lógica de negocio. Candidato ideal para Notification Service y Session Service
	Azure Face API	Servicio cognitivo de reconocimiento facial y liveness detection consumido por Onboarding Service. Soporte directo a proceso de negocio
AI Layer	*Azure AI Search	Servicio de búsqueda inteligente con capacidades de búsqueda vectorial y recuperación semántica potenciada por IA (opcional).
	Azure AI Document Intelligence	Servicio cognitivo para extracción y análisis de información en documentos. Capa propia de servicios cognitivos para validación de documentos personales.
Network and Messaging Layer	Azure Virtual Network (VNet)	Aislamiento y segmentación de red privada para todos los recursos Azure
	Subnets	Segmentación lógica dentro de la VNet por función (frontend, backend, datos)
	Azure ExpressRoute (Hybrid Connectivity)	Conexión privada dedicada entre red on-premise y Azure. No pasa por internet. Latencia consistente, hasta 100 Gbps, SLA 99.9%
	VPN Gateway (Site-to-Site) (Hybrid Connectivity)	Conexión cifrada IPSec entre red on-premise y Azure sobre internet público. Hasta 10 Gbps. Latencia variable por depender de internet.

Capa	Servicio / Tecnología	Justificación
	Private Endpoints	Acceso privado a servicios PaaS de Azure via Azure Private Link, sin tráfico por internet
	Private DNS	Resolución de nombres privada dentro de la VNet para los private endpoints
	Azure Service Bus	Bus de mensajería asíncrona. Desacopla servicios transaccionales de Notification y Audit Service. Protocolo AMQP
	Azure Event Hubs	
Data and Persistence Layer	Azure SQL Database o Azure PostgreSQL o BD on-premise	Persistencia de datos transaccionales (transferencias, pagos). Opción cloud o on-premise según estrategia de BP
	Azure SQL Database o Azure PostgreSQL (Event Store)	BD de Auditoría — Event Store append-only (CQRS + Event Sourcing). Solo INSERT, nunca UPDATE ni DELETE
	Azure Cache for Redis	Caché en memoria para datos frecuentes del cliente. Patrón Cache-Aside
	Azure Blob Storage	Almacenamiento de objetos no estructurados: documentos, imágenes, archivos
Monitoring and Auditing Layer	Azure Monitor	Recolección centralizada de métricas e infraestructura. Capa transversal de observabilidad
	Application Insights	Monitoreo de rendimiento de aplicaciones, trazas distribuidas y detección de anomalías
	Log Analytics Workspace	Almacenamiento y consulta centralizada de logs de todos los servicios
	OpenTelemetry	Estándar de instrumentación abierto que Azure Monitor usa como base para recopilar trazas, métricas y logs. No es un servicio Azure — es el protocolo de instrumentación implementado como librería dentro de los microservicios. Se exporta hacia Azure Monitor
DevOps / Platform Layer	Azure Bicep	Lenguaje declarativo nativo de Azure para aprovisionar infraestructura. Compila a ARM templates. Bicep es la opción nativa para proyectos Azure-centric que valoran simplicidad e integración con herramientas Microsoft.

Capa	Servicio / Tecnología	Justificación
DevOps / Platform Layer	Terraform	Herramienta IaC multi-cloud. Terraform es la opción para entornos multi-cloud o híbridos que requieren gestión de estado y portabilidad entre proveedores.



COSTOS AZURE

Son valores referenciales considerando que tendrán segmentos de redes privadas para todos los ambientes y depende de la transaccionalidad:

- Desarrollo
- Qa
- Producción.

Costos ambiente desarrollo

Service type	Description	Estimated monthly cost
Static Web Apps	Standard tier	\$9,00
API Management	API Developer Service,	\$48,00
Logic Apps	Workloads: Standard plan,	\$175,16
Azure Communication Services	Phone numbers leasing:	\$11,00
Foundry Tools	Face API, Standard tier:	\$2,00
Azure Kubernetes Service (AKS)	Standard	\$70,08
Azure Container Registry	Basic Tier, 1 registry x 30 days,	\$5,10
Azure Functions	Flex Consumption tier	\$7,80
Virtual Network	East US (Virtual Network 1):	\$4,00
Azure Private Link	5 Endpoints	\$38,50
Service Bus	Basic tier: 1 million messaging operations	\$0,05
Event Hubs	Basic tier:	\$10,95
Azure SQL Database	Single Database, DTU Purchase Model,	\$73,61
Azure Database for PostgreSQL	Flexible Server Deployment, General Purpose	\$130,52
Azure Cache for Redis	Basic tier; 1 C0 instances, 730 Hours	\$16,06
Azure Monitor	Log analytics: Log Data Ingestion:	\$18,11
Key Vault	Vault: 1	\$0,03
		\$619,96

Costos ambientes QA

Por optimización de costos el ambiente de QA puede ser apagado en las noches

Service type	Description	Estimated monthly cost
Static Web Apps	Standard tier	\$9,00
API Management	API Developer Service,	\$48,00
Logic Apps	Workloads: Standard plan,	\$175,16
Azure Communication Services	Phone numbers leasing:	\$11,00
Foundry Tools	Face API, Standard tier:	\$2,00
Azure Kubernetes Service (AKS)	Standard	\$70,08
Azure Container Registry	Basic Tier, 1 registry x 30 days,	\$5,10
Azure Functions	Flex Consumption tier	\$7,80
Virtual Network	East US (Virtual Network 1):	\$4,00
Azure Private Link	5 Endpoints	\$38,50
Service Bus	Basic tier: 1 million messaging operations	\$0,05
Event Hubs	Basic tier:	\$10,95
Azure SQL Database	Single Database, DTU Puede ir en lugar del Postgres	\$73,61
Azure Database for PostgreSQL	Flexible Server Deployment, Puede ir en lugar del SQL	\$130,52
Azure Cache for Redis	Basic tier; 1 C0 instances, 730 Hours	\$16,06
Azure Monitor	Log analytics: Log Data Ingestion:	\$18,11
Key Vault	Vault: 1	\$0,03
		\$619,96

Costos ambientes PRD

Service type	Description	Estimated monthly cost
Static Web Apps	Standard tier,	\$18,00
API Management	API Management v2 Service, Premium Tier,	\$2.800,00
Logic Apps	Workloads: Standard plan,	\$175,16

Azure Communication Services	Phone numbers leasing: 3 local and 4 toll-free United States (+1) phone number(s); Phone number lookup: 10000 line type queries	\$409,70
Foundry Tools	Face API, Standard tier:	\$2,00
Azure Kubernetes Service (AKS)	Standard; Cluster management for 1 clusters;	\$493,48
Azure Container Registry	Standard Tier, 1 registry x 30 days, 1	\$20,10
Azure Functions	Premium tier, Pay as you go,	\$291,85
Virtual Network	100 GB Outbound Data Transfer; East US (Virtual Network 2): 100 GB Outbound Data Transfer	\$4,00
Azure Private Link	100 GB Outbound data processed, 100 GB Inbound data processed	\$38,50
Service Bus	Standard tier:	\$79,41
Event Hubs	Standard tier:	\$22,18
*Azure SQL Database	Single Database, vCore, Puede ir en lugar del Postgres	\$736,67
Azure Database for PostgreSQL	Flexible Server Deployment, Puede ir en lugar del SQL	\$520,34
Azure Cache for Redis	Standard tier; 1 C1 instances, 730 Hours	\$100,74
Azure Monitor	Log analytics: Log Data, Application Insights:	\$152,06
Key Vault	Vault:	\$30,18
		\$5.894,37

Costos Servicios transversales.

Service type	Description	Estimated monthly cost
Azure ExpressRoute	ExpressRoute, Zone 2, 100 Mbps Standard Unlimited + ErGw1AZ	Desde 1,100 \$ hasta los 3,000
VPN Gateway	ExpressRoute Gateways, Standard tier	\$138,70
Microsoft Defender for Cloud	Microsoft Defender for Cloud Security	\$102,20
Azure Front Door	Azure Front Door Premium -	\$346,01
		\$1.686,91

ANEXO

<https://github.com/jloachaminbit/BP-Arquitectura>

[jloachaminbit/BP-Arquitectura: Ejercicio de Arquitectura](#)